



湖南工商大学
HUNAN UNIVERSITY OF TECHNOLOGY AND BUSINESS

本科生课程设计

课 程： 物联网安全技术
题 目： 基于 MQTT 的新能源充电桩身份认证与数据安全设计
学 院： 计算机学院
专业班级： 物联 2301
姓 名： 罗艳
学 号： 2309060015
任课教师： 谭利娜
提交日期： 2026 年 06 月 08 日

本科生课程设计评分表

指标	评价内容	评价等级（分值）					得分
		A	B	C	D	E	
文档规范	1、文档是否规范 2、内容是否充实 3、结构是否合理	9	8	7	6	<6	
功能分析	1、功能分析是否全面 2、功能划分是否合理 3、功能描述是否清晰	18-20	16-17	14-15	12-13	<12	
算法设计	1、算法设计的创新性 2、算法设计的科学性 3、算法设计的有效性	18-20	16-17	14-15	12-13	<12	
系统实现	1、功能实现是否全面 2、系统运行是否流畅 3、模块划分是否合理	18-20	16-17	14-15	12-13	<12	
效果分析	1、是否达到预期效果 2、结果描述是否清晰 3、问题分析是否深刻	18-20	16-17	14-15	12-13	<12	
设计总结	1、总结是否全面 2、总结是否客观 3、展望的创新性	9	8	7	6	<6	
成绩：		评阅教师签名：					
	评阅时间： 年 月 日						

基于 MQTT 的新能源充电桩身份认证与数据安全设计

摘要

随着新能源汽车的快速普及,新能源充电桩已成为智能交通和物联网领域的重要基础设施。充电桩在运行过程中需要完成用户身份认证、设备通信、订单结算以及远程管理等业务,涉及大量用户隐私数据和设备运行数据。如果缺乏有效的安全防护机制,容易遭受非法接入、数据窃听、数据篡改、重放攻击以及恶意设备入侵等安全威胁。针对上述问题,本文设计并实现了一种基于 MQTT 协议的新能源充电桩身份认证与数据安全系统。系统采用用户身份认证、设备 Token 认证、AES 数据加密、SHA256 完整性校验、时间戳防重放攻击、白名单与黑名单机制、RBAC 权限控制以及固件完整性校验等安全技术,构建新能源充电桩多层次安全防护体系。本文采用 Python 语言完成系统仿真实现,通过 MQTT 消息中间件模拟新能源充电桩与后台管理平台之间的数据交互过程。实验结果表明,所设计系统能够有效识别非法设备接入行为,保障充电数据传输的机密性和完整性,实现用户隐私保护和访问权限管控,并具备一定的攻击检测与防护能力,能够较好地满足新能源充电桩物联网场景下的安全需求,为充电基础设施安全防护体系建设提供了一定的参考价值。

关键词

MQTT; 新能源充电桩; 身份认证; AES 加密; 物联网安全

目 录

1. 选题背景	1
1.1 新能源充电桩发展现状	1
1.2 课题研究意义	1
2. 安全功能分析	2
2.1 系统总体架构分析	2
2.2 新能源充电桩安全风险分析	2
2.3 物联网三层安全架构分析	4
2.4 系统安全功能设计	5
3. 算法设计	6
3.1 用户身份认证机制设计	6
3.2 设备身份认证机制设计	7
3.3 MQTT 通信机制设计	8
3.4 AES 数据加密机制设计	9
3.5 SHA256 完整性校验机制设计	11
3.6 时间戳防重放机制设计	11
4. 系统仿真	12
4.1 系统运行环境与仿真平台	12
4.2 用户身份认证仿真	12
4.3 设备身份认证与通信仿真	13
4.4 云端数据接收与安全验证仿真	14
4.5 业务处理与权限控制仿真	14
4.6 固件完整性校验仿真	15
5. 系统测试及安全评估	15
5.1 身份认证机制测试	15
5.1.1 非法用户接入测试	15
5.1.2 非法设备接入与黑名单封禁测试	16
5.1.3 非法 Topic 权限控制测试	16
5.1.4 非法 Token 认证测试	17
5.2 数据安全机制测试	17
5.2.1 AES 数据加密测试	17

5.2.2 数据完整性测试	17
5.2.3 重放攻击测试	18
5.3 设备运行状态检测测试	18
5.4 系统安全评估	19
6. 总结	20
6.1 设计总结	20
6.2 存在的问题与不足	20
6.3 展望	21
参考文献	21

1. 选题背景

1.1 新能源充电桩发展现状

随着“双碳”战略的深入推进和新能源汽车产业的快速发展，新能源汽车保有量持续增长，带动了充电基础设施建设规模的不断扩大。作为新能源汽车的重要配套设施，充电桩承担着车辆能源补给的重要任务，其智能化和网络化水平直接影响新能源汽车产业的发展。现代新能源充电桩已不仅是传统供电设备，而是融合了物联网、云计算和移动互联网等技术的智能终端。用户通过手机 APP、小程序或充电卡完成身份认证后，充电桩能够实时采集充电状态、电压、电流、充电电量及计费信息等数据，并通过网络上传至云平台，实现远程监控、订单管理和设备运维等功能。

在充电桩与管理平台之间，MQTT 协议因具有轻量级、低带宽占用和支持发布/订阅模式等特点，被广泛应用于数据传输过程。然而，随着充电桩联网规模不断扩大，其面临的安全风险也日益突出，如非法设备接入、数据窃听、数据篡改、重放攻击以及用户隐私泄露等问题。一旦发生安全事件，不仅会影响充电业务的正常运行，还可能造成用户信息泄露和经济损失。因此，研究新能源充电桩身份认证与数据安全防护技术，构建安全可靠的物联网通信体系，具有重要的现实意义和应用价值。

1.2 课题研究意义

随着物联网技术在新能源充电领域的广泛应用，充电桩系统逐渐实现了智能化和网络化管理，但同时也面临身份伪造、数据窃听、数据篡改、重放攻击以及恶意设备接入等安全威胁。为保障充电桩设备和平台的安全运行，本课题以 MQTT 协议为通信基础，结合新能源充电桩实际应用场景，设计了一套集身份认证、数据加密、完整性校验、访问控制和固件安全于一体的安全防护方案。系统采用用户身份认证与设备 Token 认证实现双重身份验证，利用 AES 加密保障数据传输机密性，采用 SHA256 算法实现数据完整性校验，并结合时间戳机制抵御重放攻击，同时通过白名单、黑名单机制实现恶意设备防护，通过 RBAC 模型实现权限分级管理，并利用固件完整性校验保障设备运行安全。本课题将物联网

安全相关技术与新能源充电桩场景相结合，不仅有助于提高系统安全防护能力，也能够加深对身份认证、数据加密、访问控制等物联网安全技术的理解，对新能源充电桩安全体系建设具有一定的实践价值和参考意义。

2. 安全功能分析

2.1 系统总体架构分析

本系统基于 MQTT 物联网通信架构构建新能源充电桩安全防护模型，整体采用“充电桩终端—MQTT 通信网络—云端管理平台”的三层架构。充电桩终端负责用户认证、充电数据采集与上传；MQTT Broker 负责消息转发与通信管理；云端平台负责数据接收、安全验证以及业务处理。系统通过 MQTT 协议实现充电桩与云端之间的数据交互，完成充电业务全过程管理。系统总体框架如下图 2-1 所示。

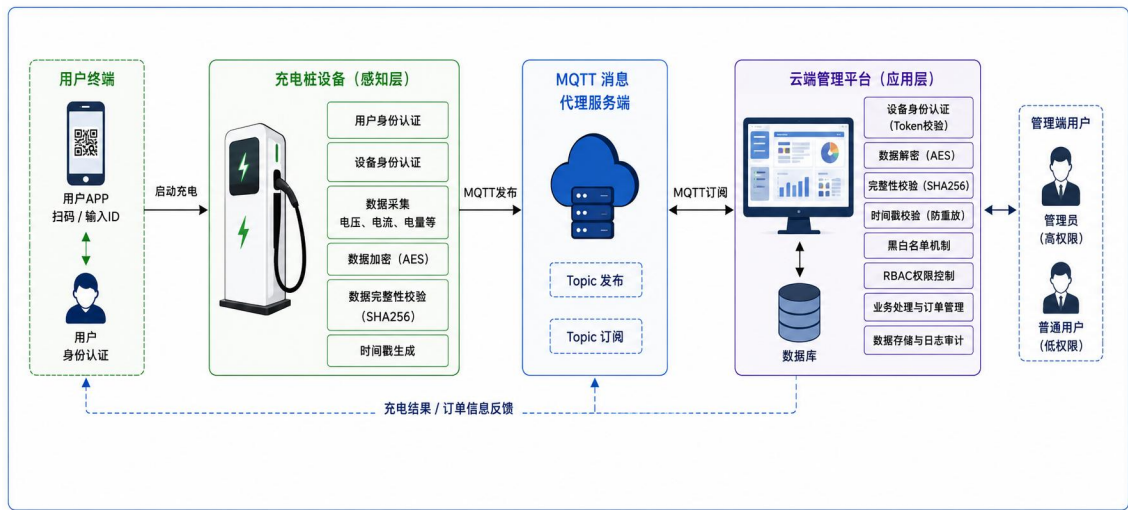


图 2-1 系统总体框架

2.2 新能源充电桩安全风险分析

在新能源充电桩接入物联网环境后，系统由传统封闭式控制模式转变为基于网络通信的开放式架构，其安全边界被显著扩展，攻击面随之增加。在 MQTT 通信机制下，数据需要在终端设备与云端平台之间频繁交互，因此系统在身份认证、数据传输、权限管理及设备可信性等方面均面临潜在安全风险。

（1）非法用户接入风险

由于充电系统涉及实际能源计费，如果身份认证机制设计不完善，攻击者可能通过伪造用户身份、重放认证请求或绕过前端验证流程的方式非法启动充电业务，从而造成电能资源被恶意占用以及虚假订单生成，影响系统计费的准确性与经济安全。

（2）非法设备接入风险

在物联网环境中，设备通常通过唯一标识符（如 Device ID 或 Token）进行识别。如果缺乏设备身份绑定机制或双向认证机制，恶意设备可能伪装成合法充电桩接入 MQTT 网络，并持续向云端上传伪造充电数据，从而污染数据源并影响后台统计结果的可靠性。

（3）数据窃听风险

MQTT 协议在基础实现中通常采用明文传输，如果未引入加密机制，充电过程中的电压、电流、电量及用户身份等敏感信息可能在网络传输过程中被中间节点截获，从而造成用户隐私泄露，并可能被用于后续攻击。

（4）数据篡改风险

在数据传输过程中，如果缺乏完整性校验机制，攻击者可能对数据包进行非法修改，例如篡改充电电量或计费金额等关键字段，从而影响计费结果的正确性，甚至破坏系统运行逻辑。

（5）重放攻击风险

攻击者通过截获合法数据包并重复发送，使系统误认为该请求为新的合法请求，从而导致重复计费、重复订单生成或状态异常等问题。

（6）权限滥用风险

在权限控制机制不完善的情况下，普通用户可能通过接口漏洞或非法提权方式获取管理员权限，从而访问或修改系统核心配置数据，对系统整体安全造成严重威胁。

（7）固件篡改风险

充电桩作为长期运行的嵌入式设备，如果缺乏固件完整性校验机制，攻击者可能通过非法刷写固件或植入恶意代码的方式控制设备运行行为，导致数据异常或设备失控。

综上所述，系统安全风险覆盖用户层、设备层、网络层以及系统管理层多个维度，具有明显的层级性与传播性特点。因此，有必要从系统架构层面构建分层安全防护机制，并在功能设计中引入多种安全技术手段进行综合防护。

2.3 物联网三层安全架构分析

为有效应对上述安全风险，本系统基于物联网分层模型构建三层安全防护体系，从感知层、网络层及应用层三个维度实现对充电桩系统的全方位安全保护，从而形成端到端的安全控制机制，物联网三层安全架构如下图 2-2 所示。

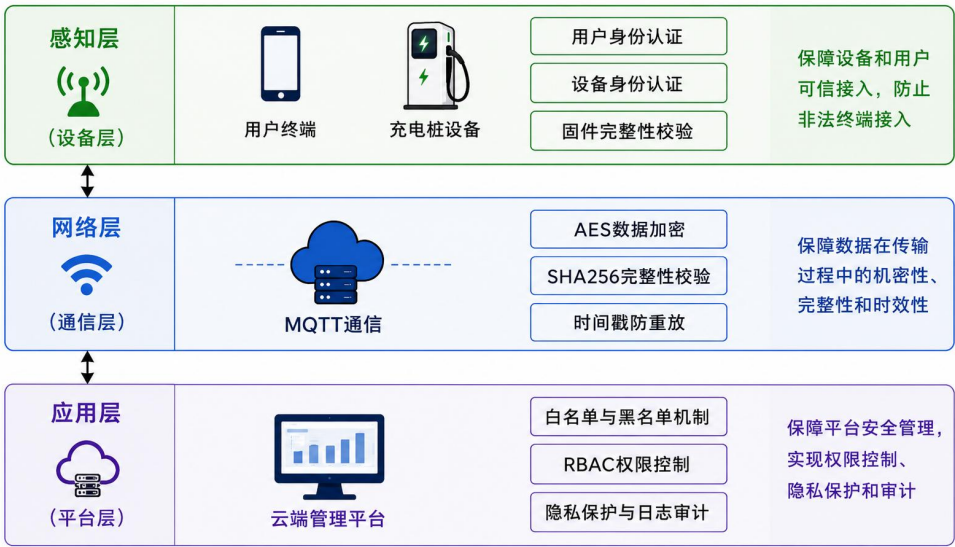


图 2-2 物联网三层安全架构

（1）感知层安全设计

感知层主要由充电桩设备、传感器模块及用户交互终端组成，负责用户身份识别与充电数据采集。针对设备伪造、非法接入等安全风险，系统采用用户身份认证和设备身份认证机制，对用户与设备进行合法性验证。同时引入固件完整性校验机制，保障设备运行环境的可信性。

（2）网络层安全设计

网络层基于 MQTT 协议实现充电桩与云端平台之间的数据通信。针对数据窃听、数据篡改以及重放攻击等安全威胁，系统采用 AES 加密机制保障数据机密性，利用 SHA256 算法实现数据完整性校验，并通过时间戳机制防止重放攻击，提高数据传输安全性。

（3）应用层安全设计

应用层主要负责数据处理、业务管理及安全控制。针对越权访问、非法设备接入以及隐私泄露等问题，系统采用 RBAC 权限控制、黑白名单管理及数据脱敏等机制，实现访问控制、设备管理和用户隐私保护，提升系统整体安全性。

2.4 系统安全功能设计

基于物联网系统安全需求分析，本系统围绕新能源充电桩业务流程构建了多层次安全防护体系，覆盖用户接入、设备认证、数据传输与系统管理等关键环节。通过模块化设计，实现对充电全过程的安全控制与风险防护。系统整体数据流程如下图 2-3 所示。

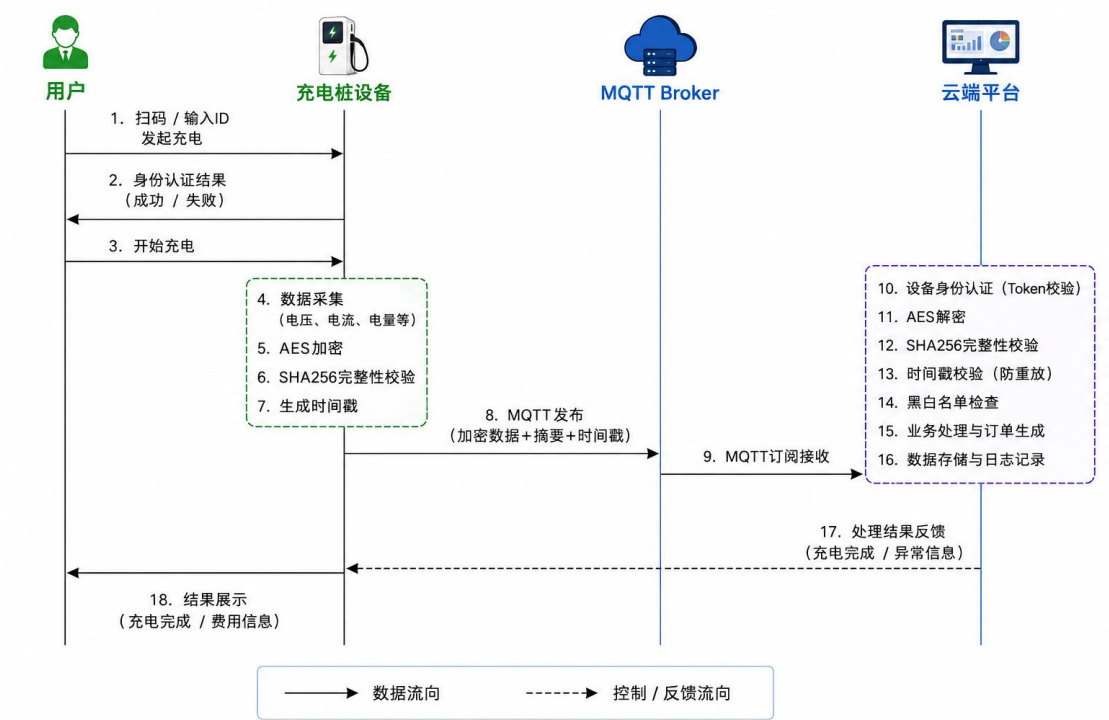


图 2-3 系统整体数据流程图

(1) 用户身份认证模块

用户身份认证模块用于实现对充电用户身份的合法性识别，是系统访问控制的第一道防线。用户在进行充电操作前需完成身份验证，系统通过对用户身份信息进行匹配校验，确认其合法性后方可进入后续流程，从而防止非法用户接入系统。

(2) 设备身份认证模块

设备身份认证模块用于对接入系统的充电桩设备进行身份校验，确保设备具备唯一性与合法性。系统通过对设备标识信息进行验证，实现对非法设备接入的有效拦截，从而保障数据来源的可信性。

(3) 数据安全传输模块

数据安全传输模块用于保障充电数据在网络传输过程中的安全性,通过对数据进行加密与完整性保护,防止数据在传输过程中被窃取或篡改,从而提高系统通信安全水平。

(4) 时间戳防重放模块

时间戳防重放模块用于防止攻击者重复发送历史数据包,通过引入时间戳机制保证数据的时效性。当数据超出有效时间窗口时,系统将拒绝处理,从而避免重复计费或异常状态产生。

(5) 访问控制模块

访问控制模块用于实现系统内部不同角色的权限管理,根据用户角色分配不同操作权限,从而防止越权访问行为,提高系统整体安全性与可控性。

(6) 数据安全辅助模块

数据安全辅助模块主要用于对用户敏感信息进行脱敏处理,在数据展示或日志记录过程中隐藏部分关键信息,从而降低隐私泄露风险。

(7) 固件安全管理模块

固件安全管理模块用于保障设备运行环境的可信性,通过对固件完整性进行校验,防止恶意固件或篡改程序运行,从而提高设备运行安全性。

3. 算法设计

为保障新能源充电桩系统在数据采集、传输与处理过程中的安全性与可靠性,本系统结合充电业务特点,构建了涵盖身份认证、数据传输保护及安全验证的多层安全防护机制。通过用户认证、设备认证、数据加密、完整性校验以及防重放攻击等措施,实现对充电全过程的安全保障。本章对系统各安全机制的设计与实现进行介绍。

3.1 用户身份认证机制设计

用户身份认证机制是系统访问控制的第一道防线,用于验证用户身份的合法性。在本系统中,用户通过输入用户 ID 或模拟扫码方式进行身份识别,系统根据预设用户数据库对用户信息进行匹配验证。当用户 ID 存在于数据库中时,允

许用户进入充电流程；否则拒绝访问。该机制能够有效防止非法用户接入系统，保障充电业务安全。用户认证流程如下图 3-1 所示。

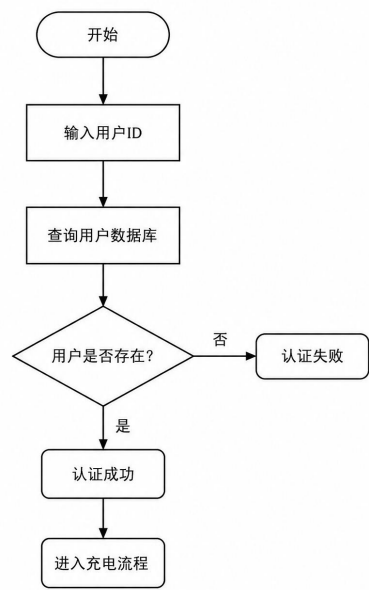


图 3-1 用户认证流程

用户身份认证通过查询预设用户数据库实现。当用户输入用户 ID 后，系统首先判断该用户是否存在于数据库中，若存在则允许进入充电流程，否则终止后续操作。其核心实现代码如下图 3-2 所示。

```
print("===== 用户身份认证 =====")

user_id = input("请输入用户ID(模拟扫码):")

if user_id not in USER_DB:
    print("用户认证失败")
    exit()

print("用户认证成功")
print("用户姓名: ", USER_DB[user_id]["name"])
```

图 3-2 用户身份认证核心代码

3.2 设备身份认证机制设计

设备身份认证机制用于确保接入系统的充电桩具备合法性与可信性，防止非法设备伪造身份接入。本系统为每个充电桩分配唯一设备标识（Device_ID），

并通过 MQTT Topic 进行通信。云端平台首先校验 Topic，验证设备是否通过合法主题传输数据，防止越权访问。

在设备接入过程中，系统采用白名单机制管理合法设备，并基于 SHA256 算法对 Device_ID 生成设备 Token。设备上传数据时需携带 Token，云端重新计算并比对完成身份验证。对于多次认证失败的设备，系统记录异常次数，达到阈值后自动加入黑名单并禁止后续接入。设备身份认证流程如下图 3-3 所示。

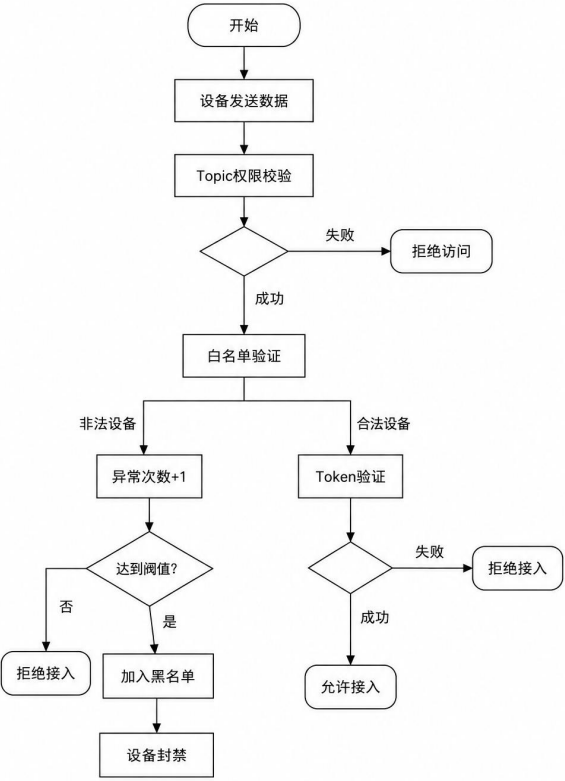


图 3-3 设备身份认证流程

3.3 MQTT 通信机制设计

本系统采用 MQTT 协议作为设备与云端之间的通信方式。MQTT 是一种基于发布/订阅模式的轻量级消息传输协议，适用于低带宽、高延迟以及资源受限的物联网环境。

在本系统中，充电桩作为发布端，将加密后的充电数据发送至指定 Topic（ev/device_id）；云端平台作为订阅端实时接收数据；MQTT Broker 负责消息转发，实现设备与平台之间的解耦通信。该机制具有结构简单、传输效率高以及

扩展性强等特点，能够满足新能源充电桩系统对实时数据传输的需求。MQTT 通信流程如下图 3-4 所示。

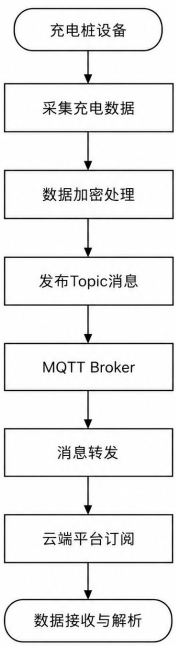


图 3-4 MQTT 通信流程

系统通过发布（Publish）与订阅（Subscribe）机制实现数据通信。充电桩端将加密后的数据发布至指定 Topic，云端平台订阅对应 Topic 并接收消息，从而完成数据交互。其核心实现代码如下图 3-5 所示。

```
# MQTT发送
# client = mqtt.Client()
client = mqtt.Client(mqtt.CallbackAPIVersion.VERSION2)
client.connect(BROKER, PORT, 60)

client.publish(TOPIC, encrypted_message)

print("\n数据已发送到Topic: ", TOPIC)
```

图 3-5 MQTT 通信核心代码

3.4 AES 数据加密机制设计

为保障充电数据在网络传输过程中的机密性，本系统采用 AES 对称加密算法对数据进行加密处理。在数据发送前，系统将用户充电信息、电量数据及计费信息封装为 JSON 格式，并采用 AES-EAX 模式进行加密，生成密文数据及认证标签（Tag）。

加密后的数据通过 MQTT 协议进行传输，即使数据在传输过程中被截获，也无法直接获取原始信息。云端接收到数据后，利用相同密钥完成解密，并验证认证标签的有效性，从而保证数据传输安全。AES 数据加密流程如下图 3-6 所示。



图 3-6 AES 数据加密流程

系统采用 AES-EAX 模式完成数据加密与解密操作。首先生成 AES 加密对象，然后对数据进行加密处理并生成认证标签，最后将密文、Nonce 以及 Tag 一并发送至云端平台。其核心实现代码如下图 3-7 所示。

```
# AES加密
def encrypt_data(data):
    cipher = AES.new(KEY, AES.MODE_EAX)
    plaintext = json.dumps(data).encode()
    ciphertext, tag = cipher.encrypt_and_digest(plaintext)
    encrypted = {
        "nonce": base64.b64encode(cipher.nonce).decode(),
        "ciphertext": base64.b64encode(ciphertext).decode(),
        "tag": base64.b64encode(tag).decode()
    }
    return json.dumps(encrypted)

encrypted_message = encrypt_data(data)

print("\nAES加密后的数据:")
print(encrypted_message)
```

图 3-7 AES 加密核心代码

3.5 SHA256 完整性校验机制设计

为保证充电订单数据在传输过程中的完整性与一致性，本系统采用 SHA256 哈希算法对关键业务数据进行完整性校验。充电桩在发送数据前对订单信息生成 Hash 值，并随数据一同上传至云端。云端接收到数据后重新计算 Hash 值并进行比对，若结果一致则继续执行业务处理，否则判定数据存在篡改风险并拒绝处理。该机制能够有效保障充电数据的完整性和计费结果的准确性，其校验流程如下图 3-8 所示。

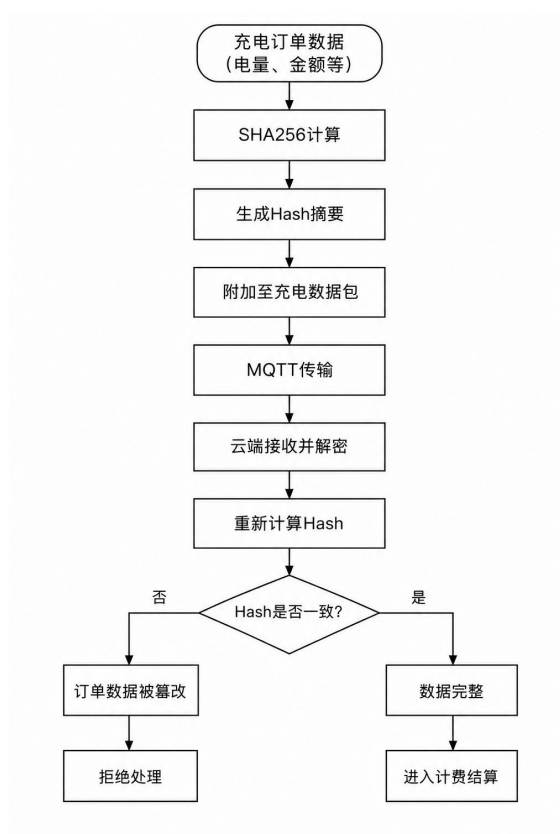


图 3-8 SHA256 完整性校验流程

3.6 时间戳防重放机制设计

为防止攻击者重复利用历史合法数据包进行重放攻击，本系统在上传数据中加入时间戳信息，并设置 30 秒有效时间窗口。云端接收到数据后，将时间戳与当前时间进行比较，超出有效范围的数据将被判定为无效并拒绝处理。该机制能够有效防止历史数据被重复利用，提高系统运行安全性。时间戳防重放流程如下图 3-9 所示。

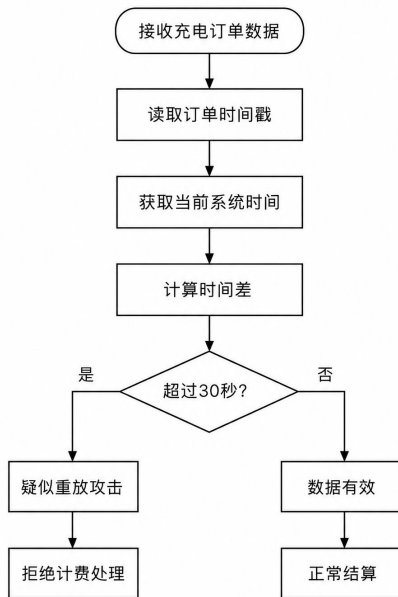


图 3-9 时间戳防重放流程

4. 系统仿真

4.1 系统运行环境与仿真平台

为验证所设计新能源充电桩物联网安全防护方案的可行性与有效性，本文采用软件仿真的方式搭建实验环境，对系统各安全功能模块进行模拟与验证。系统基于 Python 语言开发，通过 MQTT 协议实现充电桩与云端平台的数据通信，并结合 AES 加密算法、SHA256 哈希算法及权限控制机制构建整体安全防护体系。

实验环境为 Windows 操作系统，开发工具为 Visual Studio Code，Python 版本为 3.x，主要依赖 paho-mqtt 库实现 MQTT 通信，PyCryptodome 库实现 AES 加解密，hashlib 模块实现 SHA256 计算。

仿真系统由充电桩模拟端（Publisher）与云端平台模拟端（Subscriber）组成，其中充电桩负责数据采集与加密发送，云端负责数据接收、安全验证及业务处理。

4.2 用户身份认证仿真

用户身份认证是系统安全防护的第一道防线，其主要作用是验证用户身份合法性，防止非法用户接入充电系统。在本系统中，用户通过输入用户 ID 模拟扫

码认证过程。系统将输入信息与本地用户数据库进行匹配验证，当用户信息存在于数据库中时，认证通过并允许进入充电流程；否则系统终止运行并拒绝访问。实验过程中输入合法用户 ID “20260530”，系统成功完成身份认证，并显示对应用户信息，随后进入充电流程。

实验结果表明，该认证机制能够有效实现用户身份验证，为后续充电业务提供安全保障。用户身份认证成功界面如下图 4-1 所示。

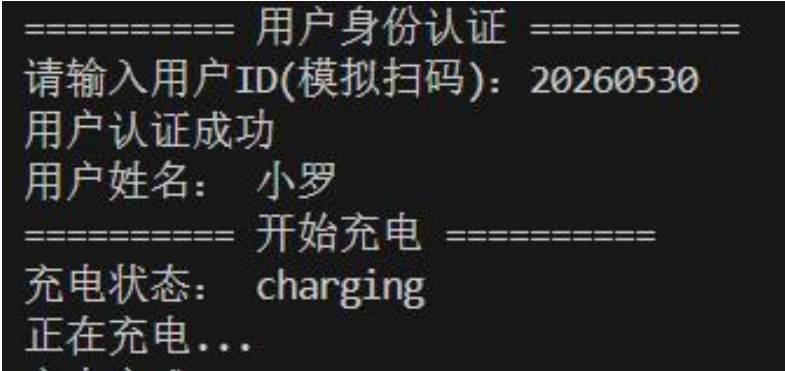


图 4-1 用户身份认证成功界面

4.3 设备身份认证与通信仿真

完成用户认证后，充电桩开始采集充电数据并向云端发送信息。系统首先根据设备 ID 生成对应 Token 作为设备身份凭证，然后对充电数据进行 AES 加密处理，并通过 MQTT 协议发布至指定 Topic。

实验结果表明，系统能够成功生成设备 Token，完成数据加密及 MQTT 消息发送，实现了设备身份认证与安全数据传输。设备认证与数据发送结果如下图 4-2 所示。

```
设备Token:
601fa4222f0dba7718408b2b86bfde7663bf8c758a1852b85f875a6eab488ff2

发送数据: {'user_id': '20260530', 'device_id': 'ev_charge_A01', 'status': 'finished', 'energy': 18.5
, 'price': 1.2, 'amount': 22.2, 'power': '45kwh', 'voltage': '380V', 'current': '32A', 'user': '18229
889540', 'token': '601fa4222f0dba7718408b2b86bfde7663bf8c758a1852b85f875a6eab488ff2', 'timestamp': 17
80644764.137274, 'hash': '0cf64a73dca26a2cd89f9bf73f0bd9106d14ec50d20d3679afa015053eb7fe77'}

AES加密后的数据:
{"nonce": "urWxWoCyrMotfz1wBko0Zg==", "ciphertext": "7VvAkgB5DwVK0wyz4tqXkGxoQwOs+7CY3lTpyJSxiBBYz1Dl
bgVroFd/AE/pSl6R286MELH1aqGsREW09KbmmB708i0xmv53EaI3bsqA4KHoz7/AEftSBZcZDAjVB/JWF7+EonZcr5Tf0D3p36eh5
Sb13hr/75F3HMr8Q0gYgz+V9Cbahn60eNewINmYc1M0cSrztIct/f0H8dhV74H46CycKGC/txbx4XeXAI/11n70+SeeRbtXSVGmr
LhfXAt2chbj6XCH9jc7+GjrmEriIn83lnQw2UBkrtnEoMlybkXscFpxqtApL5H0UuPnEsI5JnLdPUTb0fMNItrp0SCOp0AKssGZ9
poeKVovpFOZ6cnimEmQfhB7F/+9owQy2wikqZ30MTiPb9SMq1GjBzrBXbwWp/YhljC4EsEzm/C2KSEwcApcU8N8pHVguCinimfUDH
xAYv+Pdrb9xqxatrrvOY+1pv83vQ3PtYQpFnbvioDLj+Ekz13wZxunVRyY11", "tag": "MDfeenF5/wvXkL9R3lJk0Q==" }

数据已发送到Topic: ev/ev_charge_A01
```

图 4-2 设备认证与数据发送结果

4.4 云端数据接收与安全验证仿真

云端平台接收到 MQTT 消息后，首先利用 AES 密钥对接收到的密文数据进行解密，恢复原始充电业务信息。随后系统进入安全验证阶段，依次执行 Topic 权限校验、设备身份认证、Token 校验、SHA256 完整性校验以及时间戳验证等安全检测操作，以确保数据来源合法、内容完整且未发生重放攻击。

实验结果表明，系统能够正确完成数据解密与各项安全验证，上传数据均通过安全检测并进入后续业务处理流程，说明系统设计的安全机制能够满足充电数据安全传输与验证需求。云端数据接收与安全验证结果如下图 4-3 所示。

```
===== 接收到MQTT消息 =====
当前Topic:  ev/ev_charge_A01

解密后的数据:
{'user_id': '20260530', 'device_id': 'ev_charge_A01', 'status': 'finished', 'energy': 18.5, 'price': 1.2, 'amount': 22.2, 'power': '45kwh', 'voltage': '380V', 'current': '32A', 'user': '18229889540', 'token': '601fa4222f0dba7718408b2b86bfde7663bf8c758a1852b85f875a6eab488ff2', 'timestamp': 1780582484.416584, 'hash': '4f23b933f285a01d5c976e62103535423bc9e2d96fa609528cf0ae0a3cddc54d'}

===== 安全验证 =====
Topic权限校验成功
设备身份合法，继续验证...
Token校验成功
数据完整性校验成功
时间戳校验正常
设备首次上线
```

图 4-3 云端数据接收与安全验证结果

4.5 业务处理与权限控制仿真

在安全验证通过后，系统进入业务处理阶段，对充电数据进行解析与订单结算。系统首先对用户手机号进行脱敏处理，以保护用户隐私信息；随后根据充电量、电价及计费金额等数据生成订单信息，完成充电业务结算。同时，系统引入基于角色的访问控制（RBAC）机制，对管理员和普通用户进行权限划分，实现不同角色的权限管理。

实验结果表明，系统能够正确完成订单生成、隐私保护以及权限控制等功能，验证了系统业务处理模块的有效性。业务处理与权限控制结果如下图 4-4 所示。

```
脱敏手机号: 182****9540
充电功率正常

===== 业务信息 =====
用户ID: 20260530
设备ID: ev_charge_A01
充电状态: finished
累计充电量: 18.5 kwh
电价: 1.2 元/kwh
计费金额: 22.2 元

===== 订单结算 =====
订单号: ORD1780582484
用户ID: 20260530
充电量: 18.5 kwh
应付金额: 22.2 元
支付状态: 支付成功
充电记录已保存

订单状态: 已完成
充电业务完成

===== RBAC权限控制 =====
请输入管理员用户名: admin
请输入管理员密码: 123456

登录成功
当前角色: admin

管理员权限:
√ 允许远程启动充电
√ 允许停止充电
√ 允许查看充电信息
√ 允许管理设备
管理员操作日志已记录

===== RBAC权限控制 =====
请输入管理员用户名: user
请输入管理员密码: 654321

登录成功
当前角色: user

普通用户权限:
√ 允许查看充电信息
x 禁止远程启动充电
x 禁止管理设备
```

图 4-4 业务处理与权限控制结果

4.6 固件完整性校验仿真

为防止设备固件被恶意篡改，本系统设计了基于 SHA256 算法的固件完整性校验机制。系统首先对固件内容进行哈希计算，生成唯一的 SHA256 摘要值，并与本地保存的标准摘要进行比对。当两者一致时，说明固件未被修改；否则判定固件存在篡改风险。

实验结果显示，系统成功生成固件哈希值，并通过完整性校验，说明固件处于安全可信状态，固件完整性校验结果如下图 4-5 所示。

```
固件SHA256值:
0f58f8b93dfed9c40b7cce2dba712d0c18c873d7f62b0714b6c4c0ff70c4be67

固件完整性校验成功
```

图 4-5 固件完整性校验结果

5. 系统测试及安全评估

5.1 身份认证机制测试

5.1.1 非法用户接入测试

为了验证用户身份认证机制的有效性，测试时输入未注册用户 ID：99999999，系统在用户数据库中未查询到对应信息，因此终止后续充电流程。测试结果表明，系统能够有效识别非法用户身份，防止未授权用户访问充电服务。非法用户接入测试如下图 5-1 所示。

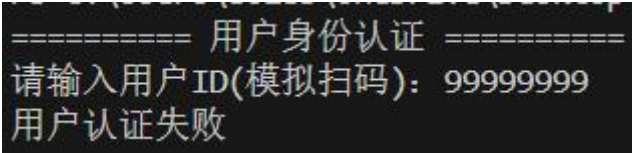


图 5-1 非法用户接入测试

5.1.2 非法设备接入与黑名单封禁测试

为验证系统对非法设备的持续防护能力，测试将设备 ID 修改为非法值 hacker001 并尝试多次接入系统。由于该设备未加入白名单，系统在接收 MQTT 数据后首先执行设备身份校验，并持续拒绝其访问请求。随着异常访问次数增加，系统自动记录设备登录失败次数，并在达到预设阈值后触发黑名单机制，将该设备加入封禁列表，从而禁止其后续访问。

测试结果表明，该机制能够有效识别并阻断非法设备的持续接入行为，实现对恶意节点的动态防护。非法设备接入与黑名单封禁测试如下图 5-2 所示。

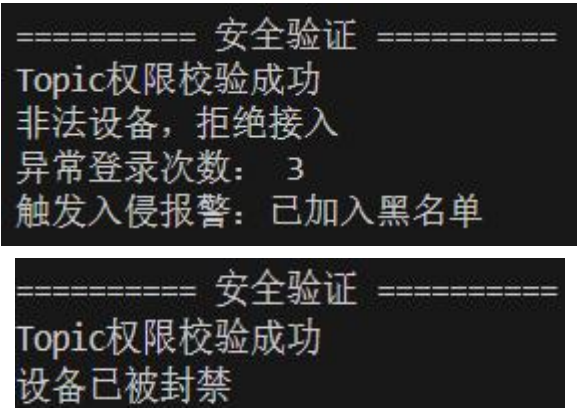


图 5-2 非法设备接入与黑名单封禁测试

5.1.3 非法 Topic 权限控制测试

为了验证 MQTT Topic 权限隔离机制，将发送 Topic 修改为：TOPIC = "ev/hacker_device"，服务器校验发现设备身份与 Topic 不匹配，因此拒绝访问。测试结果表明，系统能够有效防止非法 Topic 访问行为。非法 Topic 权限控制测试如下图 5-3 所示。

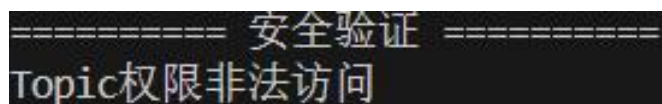


图 5-3 非法 Topic 权限控制测试

5.1.4 非法 Token 认证测试

为了验证 Token 认证机制的有效性，测试时使用非法 Token：token = hashlib.sha256("hacker001".encode()).hexdigest()，服务器重新计算合法 Token 后发现验证失败，因此终止业务处理流程。测试结果表明，Token 认证机制能够有效验证设备身份真实性。非法 Token 认证测试如下图 5-4 所示。

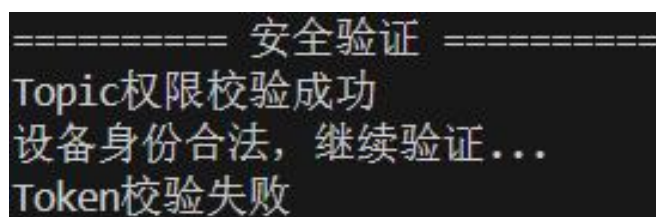


图 5-4 非法 Token 认证测试

5.2 数据安全机制测试

5.2.1 AES 数据加密测试

为了验证数据机密性保护能力，系统在发送充电数据前采用 AES-EAX 模式进行加密处理。运行结果显示，原始业务数据被转换为密文格式，仅授权平台能够完成解密操作。测试结果表明，AES 加密机制能够有效保护数据传输过程中的机密性。

5.2.2 数据完整性测试

为了验证 SHA256 完整性校验机制的有效性，在生成 Hash 值后故意修改金额字段：data["amount"] = 999，服务器重新计算 Hash 后发现数据与原始摘要不一致，因此判定数据已被篡改。测试结果表明，系统能够及时发现数据篡改行为。数据完整性测试如下图 5-5 所示。

```
82 #攻击模拟
83 data["amount"] = 999
84 print("\n发送数据:", data)
```

问题 输出 调试控制台 终端 端口 MEMORY XRTOS

```
===== 安全验证 =====
Topic权限校验成功
设备身份合法, 继续验证...
Token校验成功
数据被篡改
█
```

图 5-5 数据完整性测试

5.2.3 重放攻击测试

为了验证时间戳机制的有效性, 将发送时间修改为: `timestamp = time.time() - 100`, 系统规定数据有效时间窗口为 30 秒, 当接收到超时数据时判定为重放攻击。测试结果表明, 时间戳机制能够有效识别历史数据包。重放攻击测试如下图 5-6 所示。

```
75 "timestamp": time.time() - 100
```

问题 输出 调试控制台 终端 端口 MEMORY

```
===== 安全验证 =====
Topic权限校验成功
设备身份合法, 继续验证...
Token校验成功
数据完整性校验成功
数据超时 (疑似重放攻击)
```

图 5-6 重放攻击测试

5.3 设备运行状态检测测试

为了验证系统异常数据检测能力, 将充电功率修改为: `power = "150kwh"`, 系统检测到功率超过安全阈值后发出告警信息。测试结果表明, 系统能够及时识别异常运行状态, 异常充电功率测试如下图 5-7 所示。



图 5-7 异常充电功率测试

5.4 系统安全评估

表 5-1 身份认证机制测试结果

测试项目	测试方式	测试结果
用户身份认证	非法用户登录	拦截成功
设备身份认证	非法设备接入	拦截成功
黑名单封禁	连续异常接入	封禁成功
Topic 权限控制	非法 Topic 访问	拦截成功
Token 认证	非法 Token 伪造	拦截成功

表 5-2 数据安全机制测试结果

测试项目	测试方式	测试结果
AES 加密	密文传输验证	加密成功
SHA256 校验	数据篡改攻击	检测成功
时间戳机制	重放攻击测试	检测成功

综合测试结果表明，系统能够有效实现用户身份认证、设备接入控制、数据加密传输、完整性校验以及重放攻击防护等安全功能，并具备异常运行状态检测能力。各项安全机制均能够正常运行，验证了所设计新能源充电桩物联网安全防护方案的可行性与有效性。

6. 总结

6.1 设计总结

随着新能源汽车和物联网技术的快速发展,充电桩在为用户提供便捷充电服务的同时,也面临身份伪造、数据泄露、数据篡改以及重放攻击等安全问题。针对上述问题,本文设计并实现了一种基于 MQTT 协议的新能源充电桩身份认证与数据安全防护系统。系统围绕用户身份认证、设备身份认证、AES 数据加密、SHA256 完整性校验以及时间戳防重放等机制构建了多层安全防护体系,实现了充电数据的安全传输与可靠处理。

为了验证系统设计的有效性,本文基于 Python 搭建了充电桩模拟端与云端平台仿真环境,并开展了非法用户接入、非法设备接入、非法 Topic 访问、Token 伪造、数据篡改及重放攻击等测试。测试结果表明,系统能够有效识别非法访问行为,保障数据传输安全,具备较好的安全防护能力,验证了所设计方案的可行性与有效性。

6.2 存在的问题与不足

虽然本系统实现了新能源充电桩身份认证、数据加密、完整性校验、访问控制以及固件安全检测等功能,并完成了相关安全机制验证,但该系统仍存在以下不足。

(1) 系统仿真环境较为简单

本设计主要基于 Python 语言和本地 MQTT 服务器搭建仿真环境,验证了系统功能和安全机制的可行性,但尚未在真实新能源充电桩设备和云平台环境中进行部署测试。因此,对于复杂网络环境下的通信稳定性、设备并发接入能力以及长期运行可靠性仍缺乏进一步验证。

(2) 身份认证机制安全等级有待提高

系统采用用户身份认证、设备 Token 认证以及白名单机制实现设备合法性验证,能够有效防止非法设备接入。但当前认证方式主要基于预设身份信息进行校

验，尚未引入数字证书、双向认证等更高级的身份认证机制，在实际大规模物联网应用场景中仍有进一步优化空间。

（3）异常攻击检测能力相对有限

目前系统主要通过黑名单机制、异常设备检测以及功率异常检测实现基础安全防护，能够识别部分非法接入行为。但对于复杂网络攻击、恶意节点协同攻击以及高级持续性攻击等场景尚未进行深入研究，系统主动防御能力仍有待进一步提升。

6.3 展望

随着新能源汽车产业和物联网技术的快速发展，充电桩系统面临的安全威胁呈现多样化和复杂化趋势。为了进一步提升系统的安全防护能力和实际应用水平，未来可结合新型网络安全技术与智能分析方法，对系统进行持续优化与功能扩展，具体可从以下几个方面开展研究。

（1）构建更加完善的设备身份认证体系

未来可引入数字证书认证、PKI 公钥基础设施以及双向身份认证技术，实现充电桩设备与云平台之间的可信身份验证，提高系统抵御身份伪造和非法接入攻击的能力。

（2）增强 MQTT 通信安全防护能力

在现有 AES 数据加密机制基础上，进一步结合 TLS 安全传输协议构建 MQTT 安全通信通道，实现通信链路的端到端保护，提高系统对数据窃听和中间人攻击的防御能力。

（3）提升智能化安全检测水平

结合机器学习和异常行为分析技术，建立充电桩运行状态监测模型，对异常设备接入、异常充电行为以及潜在网络攻击进行智能识别和预警，进一步提升系统整体安全防护能力。

参考文献

[1] 张意,方明.电力电子技术在新新能源汽车充电桩中的应用[J].集成电路应用,2024,41(02):186-187.

- [2] 刘忻, 杨浩睿, 郭振斌, 等. 一种实现在线注册与权限分离的工业物联网身份认证协议 [J]. 信息网络 安全, 2021, 21(07): 1-9.
- [3] 雷璨, 陈治宇. 基于 RFID 的物联网轻量级安全认证方案 [J]. 电子技术与软件工程, 2021(24): 252-254.
- [4] 张玉清, 王蕾, 刘胜利. 智能终端安全威胁与防护技术分析 [J]. 软件学报, 2019, 30(4): 945-967.
- [5] 全国信息安全标准化技术委员会. 信息安全技术个人信息安全规范: GB/T 35273—2020 [S]. 北京: 中国标准出版社, 2020.
- [6] 袁亦凡. 电动汽车智能充电桩控制系统的研究 [J]. 现代工业经济和信息化, 2023, 13(05): 124-126.
- [7] 孙洪军, 马燕. MQTT 协议在工业设备实时数据传输中的应用与性能分析 [J]. 中国宽带, 2025, 21(11): 166-168.
- [8] 林昌盛, 郭凯凯, 杨自远. 大数据技术在电力安全智能监测系统中的应用 [J]. 电气技术与经济, 2025(8): 132-134.
- [9] 汪坤华, 朱玉鑫, 张璐. 基于改进 AES 算法的电力监控网络信息安全传输方法研究 [J]. 无线互联科技, 2025, 22(12): 90-93.
- [10] 武岳. 轻量级加密算法在物联网中应用的研究 [J]. 科技创新与生产力, 2024, 45(9): 126-129.
- [11] 石井. 物联网的信息安全技术研究 [J]. 信息记录材料, 2023, 24(7): 187-190.
- [12] 罗思源, 王跟成, 何东琴. IoT 系统的信息安全威胁分析及防护技术研究 [J]. 物联网技术, 2023, 13(08): 111-114.
- [13] 陈茹梦. 基于 AES 算法改进的物联网感知层信息安全研究 [D]. 桂林: 桂林理工大学, 2019.
- [14] Wang B. (2025). Integrated Technology and System for Risk and Safety Management in Smart Construction. Transactions on Engineering and Technology Research. <https://doi.org/10.62051/21dmgk35>.
- [15] KOLIAS C, KAMBOURAKIS G, STAVROU A, et al. DDoS in the IoT: Mirai and other botnets [J]. Computer, 2017, 50(7): 80-84.
- [16] HWANGYH. IoT security & privacy: Threats and challenges [C] // Proceedings of the 1st ACM Workshop on IoT Privacy, Trust, and Security. New York: ACM, 2015: 1-1.